

CyberShield-360 Technical Security Assessment Report

Company Selection: Volvo

1. Executive Summary

Volvo was founded in 1927, and its core business is to manufacture automotive products such as trucks, buses, construction equipment, and drive systems for marine and industrial applications. Volvo operates worldwide, with complex supply chains, advanced engineering systems, with a strong emphasis on safety, sustainability, and innovation.

The purpose of this security assessment is to evaluate cybersecurity risks affecting Volvo and identify controls that can reduce those risks. The assessment examines both digital and physical information assets, including customer data, employee records, financial information, schematics, and source code.

Information assets are classified into a three-tier system based on sensitivity and potential business impact. Tier 1 contains publicly available information, Tier 2 contains internal-use information, and Tier 3 contains highly confidential assets. This classification supports risk prioritization and helps determine appropriate security controls for protecting critical information.

2. Data Classification and Risk Assessment

2.1. Data Types Identified

- Customer data, Employee HR records, Financial records, Schematics/Source code

2.2. Classification Scheme

Scope of security Assessment:

Tier 1 (Publicly available):

- Volvo's website, Brand Trust, Marketing materials, Press release

Minimum Controls:

- Web application firewall, DDoS protection, Version control for published content.

Tier 2 (Internal Use):

- Customer data, Employee data, Internal emails, Internal documents

Minimum Controls:

- Multi-Factor Authentication, Encryption in transit (TLS 1.2+), Endpoint detection and response, Data Loss Prevention.

Tier 3 (Confidential):

- Financial records, Source code Blueprints/schematics - Intellectual Property.

Minimum Controls:

- Strict least-privilege access, Security monitoring, Network segmentation Regular vulnerability scanning & penetration testing, immutable backups, destruction policies.

Data Type	Tier	Impact Level	Minimum Required Controls
Website Content	Tier 1	Low	Web Application Firewall, DDoS protection, integrity monitoring
Internal Emails	Tier 2	Moderate	Multi-Factor Authentication, encryption in transit
Customer PII	Tier 3	High	Encryption at rest, Data Loss Prevention, GDPR compliance
Employee HR Records	Tier 3	High	Access restrictions, encryption

Financial Records	Tier 3	Critical	Encryption, network segmentation, immutable backups.
Blueprints & Source Code	Tier 3	Critical	Strict least privilege, isolated development environments

2.3. Risk Methodologies Compared

NIST SP 800-30

Prepare for risk assessment:

The purpose of this assessment is to determine the risk of the data that the company holds. The area of operations will focus on the internal data that the company holds such as confidential documents as well as employee and customer data, and as well as publicly available data.

Identify Threat Sources and Events :

Possible threats to the Volvo brand include cybercriminals, ransomware attacking Volvo's internal systems, malicious insiders (employees), and human error.

Identify Vulnerabilities and Predisposing Conditions:

Sensitive data might be accessed by employees that do not have proper clearance, backup procedures in case of inaccessibility to current data, and human error causing problems such as phishing or weak passwords.

Determine Likelihood of Occurrence:

The likelihood of occurrence is medium to high due to Volvo having sensitive data as well as having global operations so their brand is more familiar with the public eye. In addition, cyberthreats keep increasing including phishing, ransomware, automated attacks, and artificial intelligence being used is also increasing that risk.

Determine Magnitude of Impact:

- Financial loss due to operational disruption and recovery costs.
- Losing potential stakeholders due to data breaches
- Damage to the organization's reputation and brand image.
- Theft of data would result in employees and customers' data being leaked
- Public exposure of proprietary IP's and source code

Determine Risk:

The determined risk of Volvo's assets would be high because the information they hold is very sensitive. Confidential information such as financial records, proprietary IP and employee data presents a risk due to it having such a high value and potential for financial gain as well if it is stolen.

OCTAVE Allegro

Phase 1: Establish Drivers

1. Establish Risk Measurement Criteria

Impacted Area	Low	Medium	High
Financial, Data Privacy Violation	<5% of yearly revenue	5% - 10% of yearly revenue	>10% of yearly revenue
Reputation/Trust	<10% stakeholder's turnover	10% - 30% stakeholder's turnover	>30% stakeholder's turnover
Legal/Compliance	Minor Regulation Warnings	Regulatory fines, legal processes initiated	Major fines (GDPR, CCPA), lawsuits, license revocation

Phase 2: Profile Assets

Develop Information Asset Profile

Critical Asset #1: Blueprints & Schematics data

- engineering specifications, next-generation intellectual properties, safety innovations, control technologies. **Owner:** CTO / VP

Security Requirements

Asset	Description	CIA Priority
Blueprints & Schematics	Vehicle designs, battery technology, proprietary engineering	C: Critical / I: High / A: Medium
Customer & Employee Data	PII, contracts, HR and maintenance records (GDPR/CCPA)	C: Critical / I: High / A: High
Manufacturing & Supply Chain Systems	ERP, SCADA, supplier portals, production data	C: Medium / I: Critical / A: Critical

Phase 3: Identify Threats
Identified Areas of Concern

- Ransomware attacks targeting manufacturing or corporate IT systems
- Nation state espionage aimed at stealing proprietary vehicle and battery technology
- Cloud misconfigurations exposing regulated customer data
- Insider threats involving misuse of privileged access
- Supply chain compromises through third-party software or vendors

Phase 4: Identify and Mitigate Risks

Identified Risks

Scenario	Probability	Impact	Risk Level
Ransomware	Medium	High	HIGH
Espionage	Medium - High	Very High	CRITICAL
Data Breach	Low - Medium	High	HIGH

Insider Threat	Low	High	MEDIUM
Supply Chain	Low	Medium	MEDIUM

2.4. Chosen Methodology & Justification

Based on the assessment we decided that OCTAVE is the most appropriate option for this company. Volvo's risk is focused heavily on their assets with important data such as proprietary data and important financial records as well. OCTAVE Allegro focuses on identifying, prioritizing, and protecting critical information assets. OCTAVE Allegro supports risk based analysis and scenario modeling, so that future planning for mitigation will be easier.

However, NIST and OCTAVE are not always an either/or question. The two frameworks complement each other by addressing different aspects of cybersecurity risk assessment. OCTAVE Allegro was used as the primary asset-focused risk assessment methodology, while NIST SP 800-30 was used as a supporting framework for identifying threats, vulnerabilities, likelihood, impact, and overall risk. NIST Cybersecurity Framework was separately used during the gap analysis to organize security improvements.

3. Gap Analysis Plan

The gap analysis evaluates the difference between an organization's current security posture and its desired security objectives. It helps answer two critical questions: "Where are we now?" and "Where do we need to be?" By finding weaknesses, and inconsistencies, a gap analysis enables targeted, high-impact improvements rather than reactive security changes.

As a global manufacturer, Volvo operates complex supply chains and industrial control systems, so conducting a structured gap analysis is crucial for the safety and success of the company. The organization manages sensitive intellectual property, customer and employee personal data, and technology systems that must remain highly available. A single point of failure in access control, monitoring, or quarantine could result in losses such as financial loss, company disruption, or reputational damage.

The gap analysis was conducted with NIST Cybersecurity Framework (CSF) 2.0 since it is a benchmark recognized by the industry and aligns with our objectives. It organizes security into six core functions:

Govern → Identify → Protect → Detect → Respond → Recover

making it suitable for evaluating Volvo's enterprise-wide cybersecurity maturity.

3.1. Security Objectives

1. Protect Tier 3 confidential assets (financial records, blueprints, source code, PII) from unauthorized access.
2. Ensure continuous availability of manufacturing and supply chain systems.
3. Reduce the likelihood and impact of ransomware and insider threats.
4. Maintain compliance with GDPR and international data protection regulations.
5. Implement risk-based controls aligned with the NIST Cybersecurity Framework 2.0 (Govern, Identify, Protect, Detect, Respond, Recover).

3.2. Current State Assessment

Because detailed internal security architecture is not publicly available, the following conditions are assessment assumptions used to demonstrate the gap-analysis methodology.

- Partial implementation of multi-factor authentication.
- Legacy systems within manufacturing environments.
- Inconsistent privileged access management.
- Limited segmentation between corporate IT and operational technology.
- Growing reliance on third-party vendors and cloud platforms.
- Reactive rather than proactive monitoring practices.

3.3. Identified Gaps

High-Risk Gaps

- Lack of full MFA enforcement on all privileged and remote access accounts.
- Insufficient network segmentation between Tier 2 and Tier 3 assets.
- Limited implementation of Privileged Access Management (PAM).
- Over-permissioned user accounts violating least-privilege principles.
- Inadequate separation between IT and OT systems.

These gaps directly expose Tier 3 confidential assets to ransomware, insider threats, and lateral movement attacks.

Medium-Risk Gaps

- Inconsistent vulnerability scanning and penetration testing cadence.
Absence of formal immutable backup verification testing.
- Limited centralized logging and monitoring visibility.
- Incomplete vendor risk management review processes.

These gaps increase detection delays and recovery time but are less immediately catastrophic than access control weaknesses.

Low-Risk Gaps

- Limited formalization of board-level cybersecurity oversight.
- Incomplete documentation of security governance policies.

3.4. Recommendations/Roadmap

Short-Term (0–6 Months)

- Enforce MFA on all external and privileged accounts
- Conduct enterprise-wide access review
- Implement routine phishing simulation training

Mid-Term (6–12 Months)

- Deploy Privileged Access Management
- Implement network segmentation between IT and OT environments
- Conduct full penetration testing of Tier 3 assets
- Establish regular vulnerability scanning program

Long-Term (12–24 Months)

- Adopt Zero Trust Architecture principles
- Implement continuous red-team / blue-team exercises.
- Strengthen vendor risk management framework

4. Malware Attack and Breach Response

4.1. Incident Summary

In 2025, Volvo-related employee data was reportedly exposed following a ransomware attack involving an external IT supplier. Public reporting indicated that personal information associated with employees was stolen as a result of the third-party compromise. The incident demonstrates the cybersecurity risks created by trusted vendor relationships and interconnected supply chains.

Because detailed forensic information about the intrusion was not publicly available, this assessment does not assume a specific internal attack sequence. Instead, the following section presents a plausible attack path for analytical purposes.

4.2 Potential Attack Path and Contributing Factors

Based on publicly available reporting, the incident involved a compromise of a third-party vendor that resulted in unauthorized access to sensitive Volvo-related information. Public sources do not appear to provide a complete technical account of the attackers' actions inside the affected environment. Therefore, the

following represents a plausible attack path based on the available information and common supply-chain attack techniques, rather than a confirmed forensic reconstruction.

- **Initial Access / Third-Party Compromise** – Attackers gained access through a trusted third-party vendor or supplier environment. The exact initial access method was not publicly confirmed.
- **Credential or Access Abuse** – Compromised credentials or trusted vendor access may have been used to reach systems containing sensitive information.
- **Privilege Escalation** – If additional permissions were required, attackers may have attempted to obtain higher-level access within the affected environment.
- **Lateral Movement** – Attackers may have moved from the initially compromised system toward internal repositories or other systems containing sensitive data.
- **Data Exfiltration** – Public reporting indicates that sensitive data was stolen, making data exfiltration a confirmed outcome of the incident.
- **Extortion** – The stolen information was reportedly used as leverage for extortion or threatened disclosure.

4.3. Impact Assessment

Business Impact:

- Costs associated with incident response, forensic investigations, and remediation
- Potential ransom demands from attackers
- Long-term losses if proprietary technology is exposed to competitors

Operational Impact:

- Temporary shutdown or isolation of affected systems
- Disruption of product development processes
- Increased cybersecurity review and system audits

Reputational Impact:

- Damage to customer and investor confidence
- Concerns about protection of intellectual property
- Potential regulatory scrutiny regarding data protection practices

4.4. Lessons from Similar Incidents

Honda experienced a ransomware cyberattack in 2020 that forced the company to halt production at several production sites worldwide while IT systems were restored (Goodin, 2020).

- Ransomware groups increasingly target intellectual property and production systems.
- Manufacturing companies often face risk due to interconnected IT and operational technology (OT) systems.

- Third-party vendors and suppliers can introduce additional vulnerabilities into enterprise environments.
- Delayed detection of intrusions increases the likelihood of data exfiltration before response actions occur.
- These lessons highlight the need for stronger monitoring, segmentation, and incident response planning across large industrial environments.

4.5. Proposed Countermeasures

To prevent similar cybersecurity incidents in the future, Volvo should implement several key security improvements.

Strengthen Identity and Access Controls

- Enforce multifactor authentication for all privileged and remote accounts.
- Implement Privileged Access Management systems.
- Conduct regular access reviews to enforce least privilege principles.

Improve Network Segmentation

- Separate corporate IT networks from operational technology systems.
- Isolate development and engineering environments from general network access.
- Limit lateral movement between internal systems.

Enhance Monitoring and Detection

- Deploy centralized logging and Security Information and Event Management (SIEM) systems.
- Implement Endpoint Detection and Response (EDR) across corporate devices.
- Monitor unusual data access or large file transfers from sensitive repositories.

Strengthen Ransomware Resilience

- Maintain secure, offline, and immutable backups of critical data for faster recovery time.
- Conduct regular backup restoration tests to ensure backups are still valid.
- Develop incident response guides for ransomware scenarios.

Improve Vendor and Supply Chain Security

- Perform cybersecurity assessments of third-party vendors.
- Enforce strict access controls for external partners.
- Monitor vendor connections to internal networks.

By implementing these countermeasures, Volvo can reduce the likelihood of similar attacks and strengthen its overall cybersecurity posture.

5. Threat Modeling Analysis

5.1. System/Process Chosen

The selected system for threat modeling is a **web-based customer account portal** (<https://www.volvocars.com/us/>) used by Volvo customers.

This system allows users to:

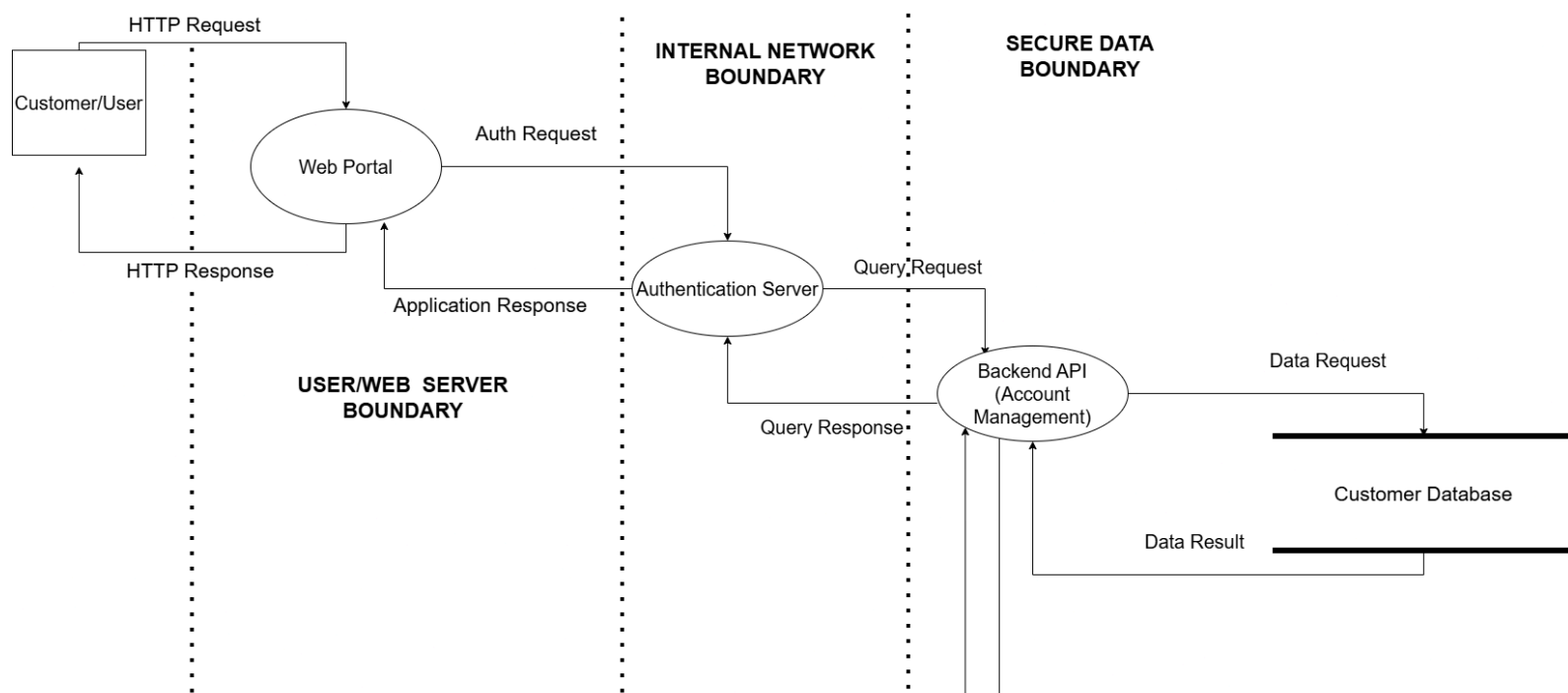
- Log in using credentials
- Access personal and vehicle data
- Schedule services and manage accounts

The system includes:

- Web browser
- Authentication service
- Database for the backend
- External APIs

This system processes and stores sensitive information that could be targeted by attackers.

5.2. STRIDE Analysis



Component	STRIDE Category	Threat Description	Suggested Mitigation
Customer/User	Spoofing	An attacker may use stolen credentials to impersonate a legitimate customer.	Enforce MFA, strong password policies, and suspicious login detection.
Web Portal	Tampering	An attacker may manipulate form inputs or requests to alter account data or inject malicious input.	Use input validation, secure session handling, and web application firewall protections.
Web Portal	Denial of Service	Attackers may flood the portal with requests, making it unavailable to legitimate users.	Implement rate limiting, DDoS protection, and traffic filtering.
Authentication Server	Spoofing	Attackers may attempt credential stuffing or brute-force attacks against login services.	Enable MFA, account lockout policies, and anomaly-based authentication monitoring.
Authentication Server	Repudiation	A user may deny login attempts or account actions if logging is weak.	Maintain centralized audit logs with timestamps and user identifiers.
Backend API (Account Management)	Elevation of Privilege	A normal user may exploit weak access controls to gain higher privileges or access restricted functions.	Enforce role-based access control, least privilege, and secure API authorization checks.

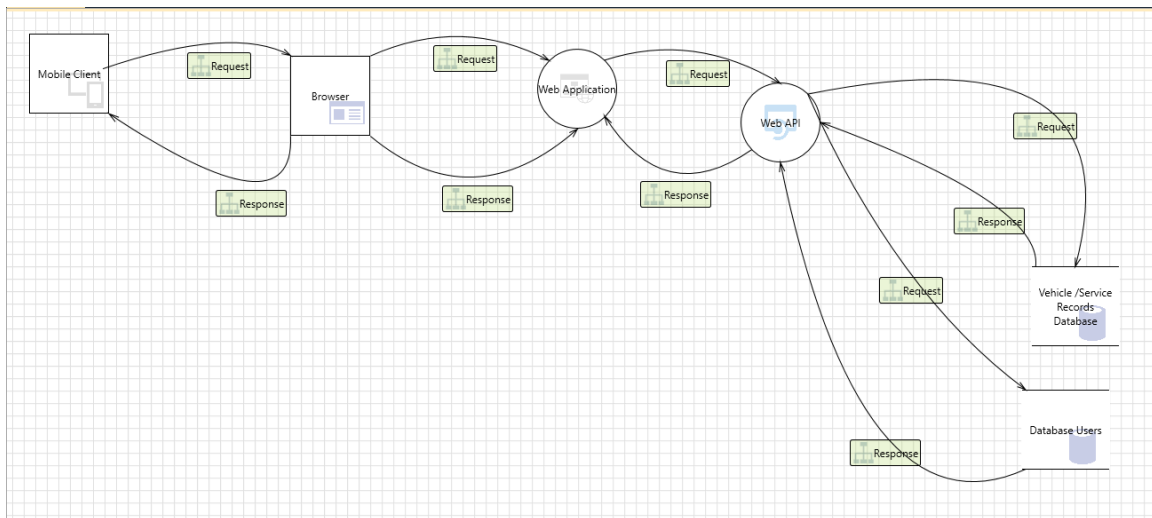
Backend API (Account Management)	Tampering	Attackers may modify API requests to access or change unauthorized records.	Use server-side validation, token-based authentication, and API security testing.
Customer Database	Information Disclosure	Sensitive customer data such as PII may be exposed if the database is compromised.	Encrypt data at rest, restrict database access, and monitor suspicious queries.
Customer Database	Tampering	Attackers may alter stored customer data or account information.	Use database integrity controls, access restrictions, and backup verification.
Vehicle / Service Records Database	Information Disclosure	Vehicle history and service records may be accessed without authorization.	Segment databases, enforce strict access controls, and log all queries.
Vehicle / Service Records Database	Repudiation	Changes to service records may not be traceable if logging is incomplete.	Enable immutable audit logging and change tracking.
Data Flows Across Trust Boundaries	Information Disclosure	Data transmitted between components may be intercepted if not properly secured.	Use TLS, secure API communications, and certificate validation.

5.3. Microsoft Threat Modeling Tool Outputs

[Microsoft Threat Detection Sheet List Excel Version](#)

[Microsoft Threat Detection Sheet List PDF Version](#)

The full Microsoft Threat Modeling Tool threat report has been exported and included to this report. This report contains detailed threat IDs, categories, and descriptions generated by the tool.



● Spoofing 20 threats

Attacks where an adversary impersonates a legitimate user, browser, or system component.

- Session hijacking via improper logout/timeout (IDs 10, 31)
- Session hijacking via insecure coding practices (IDs 11, 32)
- Insecure TLS certificate configuration enabling site spoofing (IDs 12, 33, 54)

- Credential theft via weak input validation, plaintext storage, or poor password recovery (IDs 13, 34, 55)
- Cookie theft via missing Secure/HttpOnly attributes (IDs 14, 35)
- Phishing via fake site impersonating Volvo (IDs 15, 36, 56)
- Browser spoofing Web App due to missing authentication (IDs 16, 37)
- Web App spoofing Web API (ID 47)
- Web API spoofing Web App (ID 57)
- Database users spoofing Web API (IDs 72, 87)

● **Tampering 16 threats**

Attacks that modify data, code, or traffic in transit or at rest.

- Website defacement via malicious code injection or dangerous file upload (IDs 17, 38)
- Session replay attacks by stealing and replaying network messages (IDs 18, 39)
- SQL injection through Web App (IDs 19, 40, 58)
- Config file tampering to access stored sensitive data (IDs 20, 41, 59)
- Malicious input injection into Web API affecting downstream systems (IDs 48, 73, 88)
- SQL injection through Web API (IDs 49, 74, 89)
- Database securables tampering (IDs 65, 80)
- Anomalous traffic exploitation due to lack of DB monitoring/IDS (IDs 66, 81)

● Information Disclosure **30 threats**

The largest category unauthorized access to sensitive data across all layers.

- Weak encryption/hashing allowing content reversal (IDs 2, 23, 50)
- Sensitive data leakage via log files (IDs 3, 24, 51)
- Unmasked sensitive data exposure e.g. credit card numbers (IDs 4, 25)
- Robots.txt exposing restricted pages/admin paths (IDs 5, 26)
- Traffic sniffing / MITM via missing HSTS or mixed content (IDs 6, 27, 44, 69, 84)
- Verbose error messages leaking server names, stack traces, SQL details (IDs 7, 28, 43, 52, 68, 83)
- Sensitive data in uncleared browser cache (IDs 8, 29)
- SQL injection exposing DB data (IDs 63, 78)
- PII/HBI data exposure in database (IDs 62, 77)
- Config file data exposure in Web API (IDs 45, 70, 85)

● Repudiation **8 threats**

Lack of logging allows attackers to cover their tracks and deny malicious actions.

- No audit trail on Web App actions (IDs 9, 30, 53)
- No audit trail on Web API actions (IDs 46, 71, 86)
- No audit trail on database actions (IDs 64, 79)

● Elevation of Privilege **10 threats**

Attackers gaining access or permissions beyond what they are authorized for.

- Improper validation logic allowing privilege bypass (IDs 1, 22)
- Cross-domain request abuse / CSRF (IDs 0, 21) (note: categorized as DoS in the file but functionally EoP/CSRF)
- Poor access control on Web API (IDs 42, 67, 82)
- Database access lacking network-level firewall protection (IDs 60, 75)
- Database access with overly permissive authorization rules (IDs 61, 76)

5.4 Web Application Security Header Assessment

Mapping of Header Findings to STRIDE Threats

- The missing HTTP security headers identified in the analysis directly relate to several STRIDE threat categories:
- Missing Content-Security-Policy (CSP) → enables cross-site scripting (XSS) attacks → Tampering
- Missing X-Frame-Options → enables clickjacking → Spoofing / Elevation of Privilege
- Missing Referrer-Policy → allows leakage of sensitive data → Information Disclosure

- Missing Permissions-Policy → allows misuse of browser features
→ Elevation of Privilege

These findings align with the MTMT generated threats, particularly in the categories of tampering, spoofing, and information disclosure.

 **Security Headers**
by snyk

Scan your site now

☐ Hide results ☒ Follow redirects

Security Report Summary



Site:	https://www.volvocars.com/us/
IP Address:	95.100.98.91
Report Time:	13 Apr 2026 00:51:12 UTC
Headers:	✓ X-Content-Type-Options ✓ Strict-Transport-Security ✗ Content-Security-Policy ✗ X-Frame-Options ✗ Referrer-Policy ✗ Permissions-Policy
Advanced:	Your site could be at risk, let's perform a deeper security analysis of your site and APIs: Start Now

Missing Headers	
Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Warnings	
Status code indicates error	The status code of the response indicates an error. Not all headers may be set when the response is an error.
Scan was blocked	We got a 403 when trying to scan, please ensure we aren't being blocked. You can find our IP addresses to allow scans in our FAQ.

Raw Headers	
HTTP/2	403
mime-version	1.0
content-type	text/html
content-length	378
cache-control	max-age=0
expires	Mon, 13 Apr 2026 00:51:12 GMT
date	Mon, 13 Apr 2026 00:51:12 GMT
alt-svc	h3=";443"; ma=93600
akamai-request-bc	[a=95,100.98.87,b=1752883542,c=g,n=IE_DUBLIN,o=20940]
x-content-type-options	nosniff
strict-transport-security	max-age=15768000 ; includeSubDomains ; preload

Upcoming Headers	
Cross-Origin-Embedder-Policy	Cross-Origin Embedder Policy allows a site to prevent assets being loaded that do not grant permission to load them via CORS or CORP.
Cross-Origin-Opener-Policy	Cross-Origin Opener Policy allows a site to opt-in to Cross-Origin Isolation in the browser.
Cross-Origin-Resource-Policy	Cross-Origin Resource Policy allows a resource owner to specify who can load the resource.

Additional Information	
x-content-type-options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
strict-transport-security	HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS.

- **Content-Security-Policy:** Defines which content sources the browser is allowed to load, for example: scripts, styles, images, fonts, etc... . We can observe a *risk* for injection techniques that would allow users to execute arbitrary code in the context of the website, potentially stealing cookies, credentials, or redirecting users.
- **Strict-Transport-Security (HSTS):** Forces the browser to always connect to the site over HTTPS. Protects against SSL-stripping and man-in-the-middle attacks on unencrypted connections.
- **X-Frame-Options:** Controls whether the site can be embedded on another domain. Preventing mostly clickjacking attacks. Attackers can

embed volvocars.com in a hidden iframe and trick the users into unintended actions

- **X-XSS-Protection:** A legacy header originally designed for Internet Explorer and early Chrome that triggered a built-in XSS auditor in the browser. Best practice is to disable this header or set it to “0”.
- **Referrer-Policy:** Controls how much referrer information is included in HTTP requests when navigating away from the site. Possible leak third-party analytics or ad servers via *referrer* header
- **X-Content-Type-Options:** Prevents browsers from MIME-type sniffing where a browser guesses a file's content type instead of trusting what the server declares. This blocks attacks where a malicious file (such as an image containing JavaScript) gets executed as a script because the browser misidentified it.
- **Permissions-Policy:** Restricts which browser features and API the page and embedded iframes are allowed to use. A malicious embedded or compromised script can activate user's cameras, microphone, or location without user's consent

Recommendations (Increasing Security Posture):

- **ADD**
 - Add a CSP header to whitelist trusted sources for scripts, styles, and images. Mitigates XSS and data injection attacks

- Add X-Frame-Options to prevent the site from being embedded in iframes on other domains
- Add Referrer-Policy to control how much URL information is passed when users navigate away. This helps prevent sensitive-data leakage.
- Add Permissions-Policy header to explicitly disable browser APIs the site doesn't need. Limits the damage of injection that would take control of user's personal computer features such as cameras, microphone, geolocation, etc... without consent

5.5. Top Threats Summary

To address the identified risks, the following prioritized actions are recommended:

Short-Term (0–30 Days)

- Enforce multi-factor authentication for all user accounts
- Implement missing HTTP security headers (Content-Security-Policy, X-Frame-Options, Referrer-Policy)
- Apply secure cookie configurations (HttpOnly, Secure flags)

Mid-Term (1–3 Months)

- Strengthen API security through input validation and role-based access control (RBAC)
- Implement centralized logging and monitoring (SIEM)

- Conduct vulnerability scanning and penetration testing

Long-Term (3–6 Months)

- Adopt Zero Trust architecture principles
- Improve database segmentation and encryption strategies
- Conduct red-team / blue-team security testing

The threat modeling analysis identified several critical risks affecting Volvo's web-based customer account portal, particularly in the areas of authentication, data protection, and application security. One of the most significant threats is credential compromise or spoofing, where the attacker uses stolen credentials to gain access to data that they are not authorized for. Requiring multi-factor authentication could help mitigate this type of attack. Additionally, weak API validation may allow attackers to modify or access unauthorized data. Implementing secure API design and role-based access control is critical. Finally, missing HTTP security headers on some Volvo sites increase the risk of client-side attacks such as XSS and clickjacking. Strengthening these protections will improve overall security.

6. System Hardening and Audit Logging

6.1. Platform Chosen

The platform selected for this exercise was Windows 11 Pro (23H2). This system was used to perform baseline hardening steps and monitor system activity over a 24-hour period.

6.2. Hardening Steps Performed

The following system hardening measures were implemented to improve endpoint security:

- **Antivirus Verification (Windows Defender)**

Windows Defender was verified to be active, updated, and running real-time protection. A quick scan was performed to ensure no threats were present.

- **Firewall Configuration**

The Windows Defender Firewall was enabled for all network profiles (Domain, Private, Public). Default inbound rules were restricted, and unnecessary outbound connections were reviewed.

- **Disable Unused Accounts**

Guest accounts and unused local user accounts were disabled to reduce unauthorized access risk.

- **System Updates**

All pending Windows updates were installed to ensure the system had the latest security patches.

- **Password and Lockout Policy**

Strong password requirements were enforced, including minimum length and complexity. Account lockout policies were configured to prevent brute force login attempts.

- **Disk Encryption (BitLocker)**

BitLocker encryption was enabled to protect data at rest in case of device theft or unauthorized access.

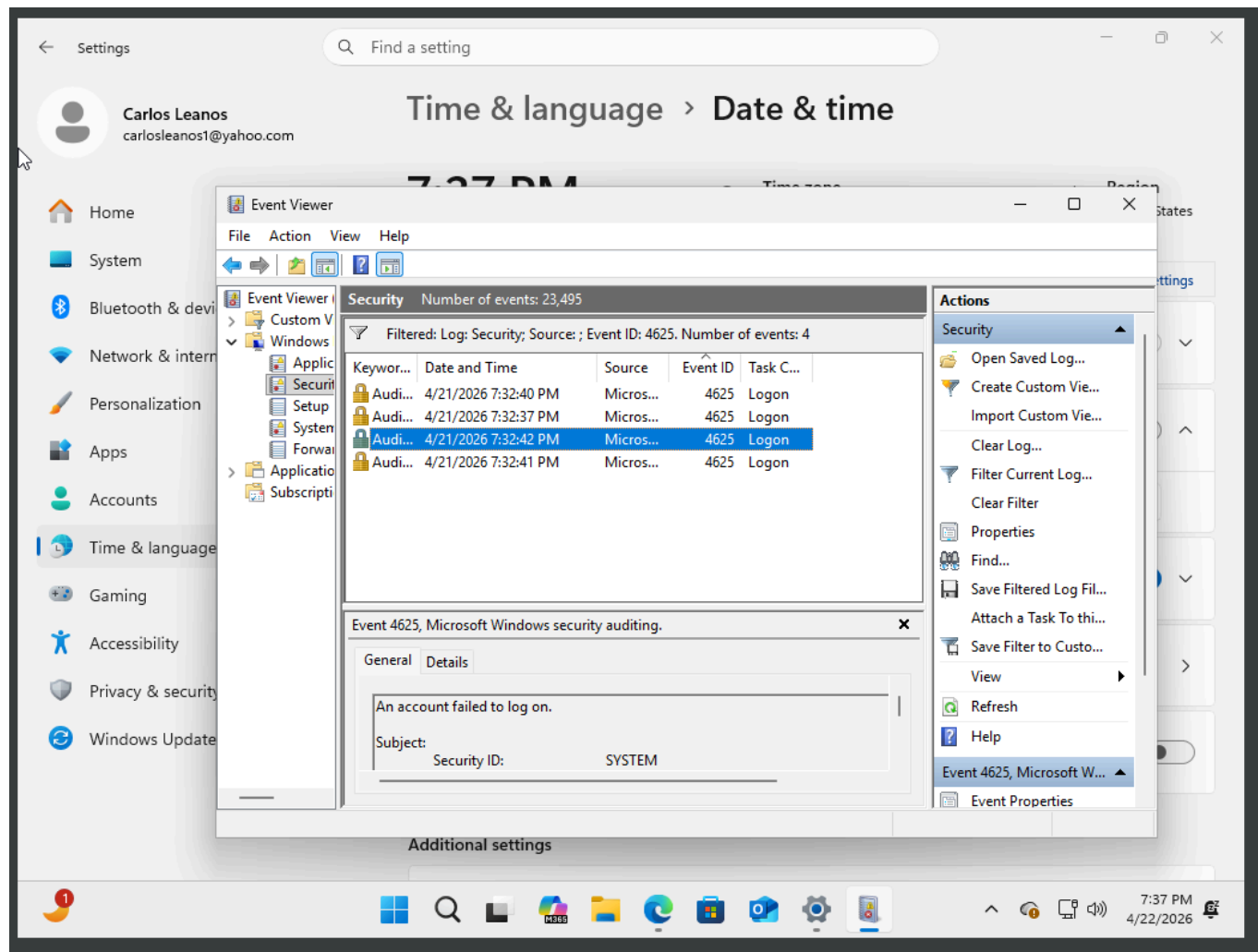
6.3. Audit Log Configuration

Audit logging was configured and monitored using Windows Event Viewer.

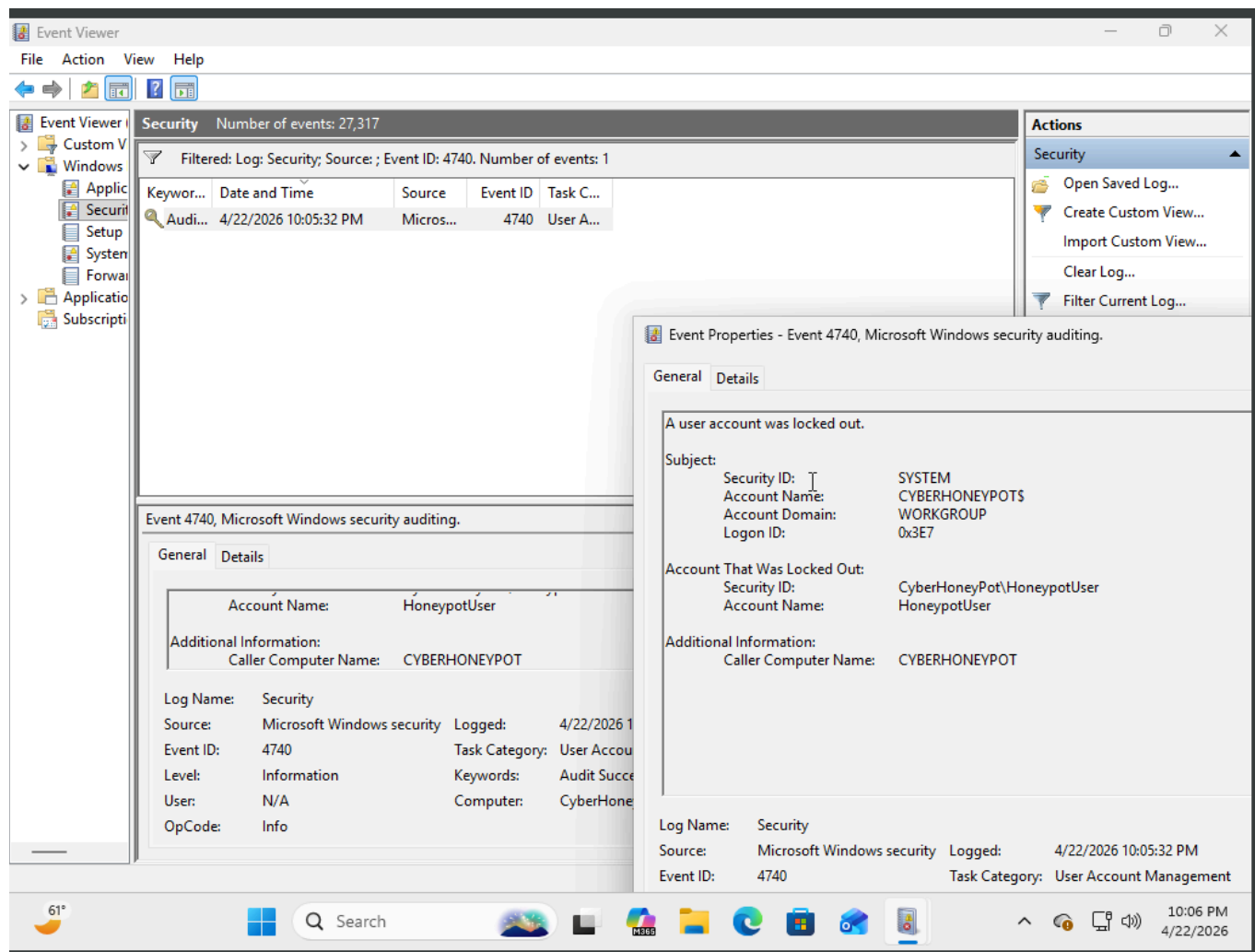
The following logs were reviewed:

- **Security Logs**

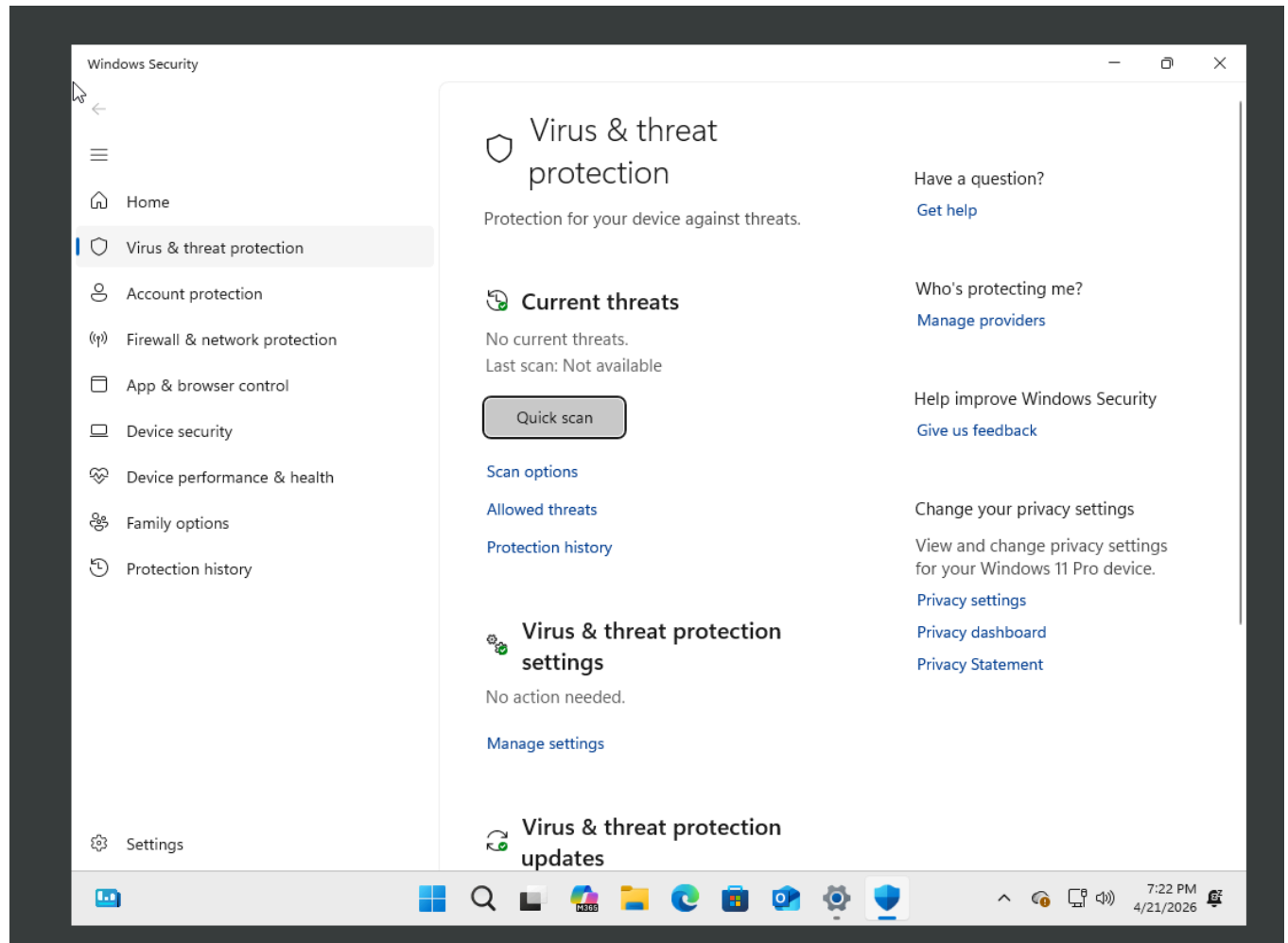
- 4625 — An account failed to log on



- 4740 — A user account was locked out

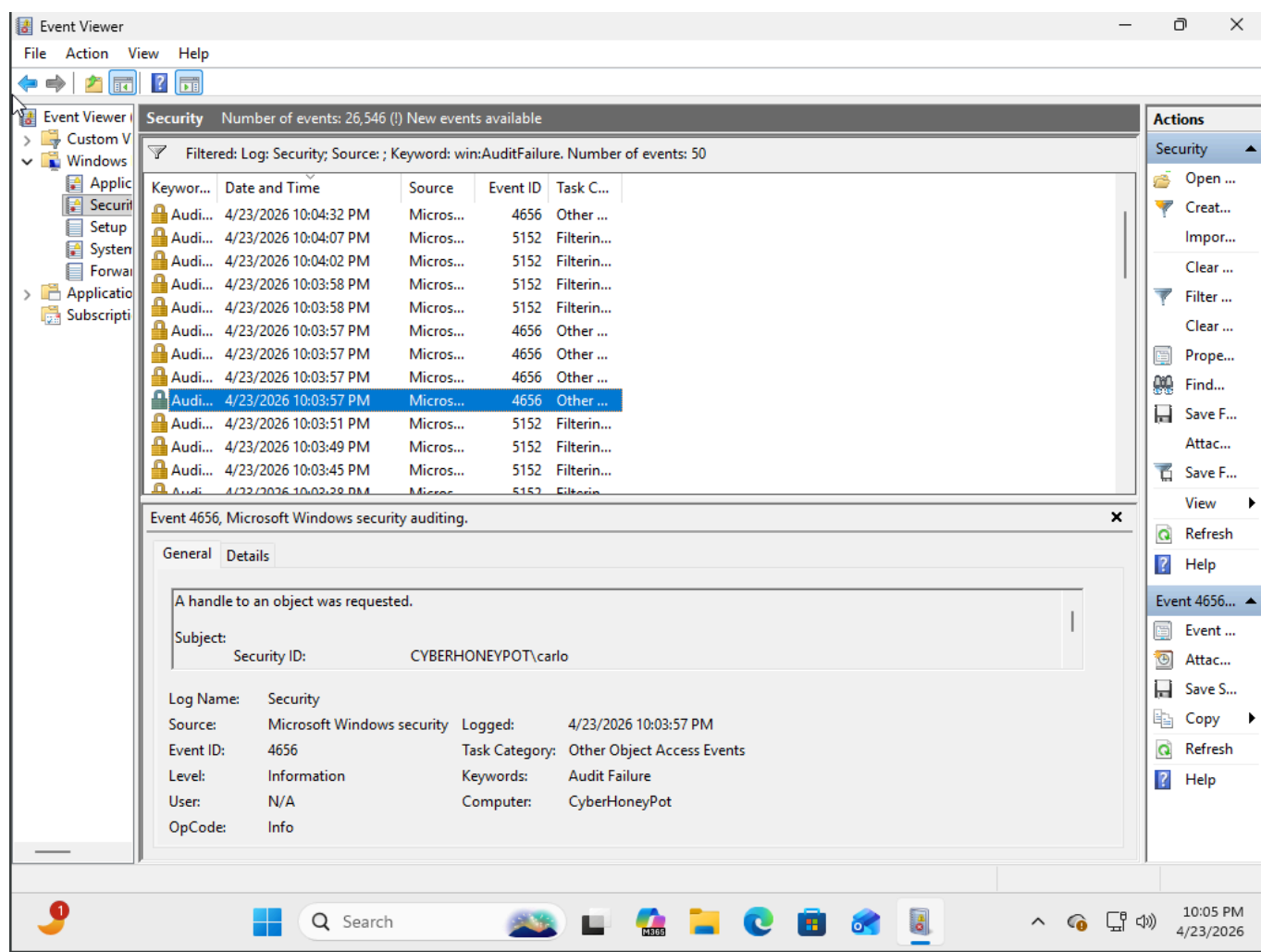


- **Windows Defender Logs**
 - Malware detection or quarantine activity



- **System Logs**

- Unusual system behavior or warnings (Insufficient privileges)



Audit policies were configured using Local Security Policy (secpol.msc) to ensure logging of login attempts and security events and monitored using Windows Event Viewer.

6.4. 24-Hour Monitoring Observations

During the 24-hour monitoring period, the following observations were made:

- A small number of failed login attempts were detected, likely due to incorrect password entry and an account lockout.
- No malware detection or quarantine events were recorded by Windows Defender.
- One user tried to access files on a system that they did not have privileges for.

Overall, the system remained stable and showed no signs of compromise during the observation period.

6.5. Security Enhancement Summary

The system hardening and audit logging activities improved the security posture of the Windows 11 workstation. The implemented controls included Windows Defender real-time protection, Windows Firewall, system updates, stronger password and account lockout policies, disabling unused accounts, BitLocker disk encryption, and Windows audit logging.

These measures reduce the likelihood of malware infection, unauthorized access, brute-force attacks, and data exposure. Audit logging also provides greater visibility into failed login attempts, account lockouts, and unauthorized access attempts, supporting earlier detection and investigation of security events.

Multi-factor authentication was identified as an additional recommended control but was not implemented as part of this workstation hardening exercise.

6.6. Emerging Threat Researched

Fileless malware is an advanced cyber threat that operates in memory without installing traditional files on a system. Instead of relying on malicious executables, attackers use legitimate system tools such as PowerShell, Windows Management Instrumentation, and other utilities installed with Windows to execute attacks. This allows fileless malware to bypass traditional antivirus detection systems.

This threat is highly relevant to organizations like Volvo because it targets endpoints such as employee workstations, which were the focus of this hardening and monitoring exercise. Since fileless malware leaves minimal traces on disk, it is more difficult to detect using standard antivirus tools like Windows Defender. Instead, detection relies heavily on monitoring system behavior and analyzing logs through tools like Event Viewer.

The implications of this threat include unauthorized access, data exfiltration, and persistence within the system without detection. If exploited, attackers could gain access to sensitive customer data or intellectual property without triggering traditional security alerts.

To mitigate this threat, organizations should:

- Enable advanced endpoint detection and response tools.
- Monitor PowerShell and system process activity through logging.
- Enforce least-privilege access controls.
- Regularly update and patch systems.
- Use behavior based-detection rather than relying solely on signature-based antivirus.

7. Summary of Recommendations

The security assessment showed several areas where Volvo can improve its overall information security posture. These recommendations are based on the risk assessment, gap analysis, incident review, threat modeling, and system hardening activities completed in this report.

First, enforcing multi-factor authentication (MFA), implementing strict password policies, and applying account lockout controls will reduce the risk of unauthorized access and credential-based attacks.

Second, improving network and system segmentation is important. Separating corporate IT systems from operational technology (OT) environments and isolating sensitive systems will limit the movement of attackers in a network and reduce the impact of potential breaches.

Third, implementing missing HTTP security headers such as Content Security Policy (CSP), X-Frame-Options, Referrer-Policy, and Permissions-Policy

will reduce exposure to client-side attacks such as cross-site scripting (XSS) and clickjacking.

Fourth, implementing centralized logging (SIEM), endpoint detection and response (EDR), and continuous monitoring will allow quicker detection of suspicious activities such as failed logins, unauthorized access attempts, and abnormal system behavior.

Finally, improving endpoint security through system hardening practices such as enabling firewalls, antivirus protection, encryption, and regular updates will protect workstations from threats such as malware and fileless attacks.

Overall, adopting a layered security approach that combines prevention, detection, and response will significantly improve Volvo's resilience against modern cybersecurity threats.

8. References

<https://www.volvocars.com/us/>

<https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

Caralli, R. A., Stevens, J. F., Young, L. R., & Wilson, W. R. (2007). Introducing OCTAVE Allegro: Improving the information security risk assessment process. Carnegie Mellon University, Software Engineering Institute.

<https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=8419>

National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (Special Publication 800-30 Rev. 1). U.S. Department of Commerce.

<https://doi.org/10.6028/NIST.SP.800-30r1>

Houghton, F., Winterburn, M., & Oakley, K. (2025). The 2023 Rhysida ransomware attack on the British Library: Prioritisation, expertise, and funding issues. *Information Technology and Libraries*, 44(1).

<https://doi.org/10.5860/ital.v44i1.17112>

Huy, S., Ang, S., Ho, M., & Balasubramaniam, V. (2025). Insider threats in the banking sector: Detection, prevention, and mitigation. *Journal of Cyber Security and Risk Auditing*, 2025(4), 257–265.

<https://doi.org/10.63180/jcsra.thestap.2025.4.5>

Rotibi, K., & Alzahabi, M. (2024). Winning the battle with cyber risk identification tools in industrial control systems. *IET Cyber-Physical Systems: Theory & Applications*, 1–16. <https://doi.org/10.1049/cps2.12105>

Volvo Group. (2024). About us. <https://www.volvogroup.com/en/about-us.html>

Volvo Group. (n.d.). *Employee privacy notice*. Retrieved February 4, 2026, from <https://www.volvogroup.com/content/dam/volvo-group/markets/master/privacy/privacy-documents/en/employee-privacy-notice.pdf>

Arghire, I. (2025, September 25). *Volvo Group employee data stolen in ransomware attack*. SecurityWeek.

<https://www.securityweek.com/volvo-group-employee-data-stolen-in-ransomware-attack/>

Jones, C. (2025, September 26). *Volvo North America confirms staff data stolen following ransomware attack on IT supplier*. The Register

https://www.theregister.com/2025/09/26/volvo_north_america_confirms_staff/

Goodin, D. (2020, June 9). *Honda halts production at some plants after being hit by a cyberattack*. Ars Technica.
<https://arstechnica.com/information-technology/2020/06/honda-halts-production-at-some-plants-after-being-hit-by-a-cyberattack/>

Fauzan, & Benfano Soewito. (2025). *Assessing information security risks in an interconnected system using OCTAVE Allegro, NIST Privacy Framework and ISO 27010:2015*. Journal of Information Systems Engineering and Management, 9(4).
<https://www.jisem-journal.com/index.php/journal/article/view/1527/604>

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce.
<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>